



UNIVERSIDAD DE LAS FUERZAS ARMADAS ESPE

DESARROLLO DE SOFTWARE SEGURO

DEPARTAMENTO DE CIENCIAS DE LA COMPUTACIÓN

Informe técnico sobre una vulnerabilidad real en software

Estudiante:

Ednan Josué Merino Calderón

Docente:

Ing. Jayli De la Torre

Índice general

1. Caso de vulnerabilidad en Equifax	2
1.1. ¿Qué ocurrió?	2
1.2. ¿Qué tipo de vulnerabilidad fue?	2
1.3. ¿Cuál fue el riesgo y el impacto?	3
1.4. ¿Qué soluciones se implementaron?	3
2. Riesgos de Seguridad en el Desarrollo de Software	4
2.1. Riesgos de Seguridad Identificados	4
2.1.1. Inyección SQL	4
2.1.2. Exposición de Datos Sensibles	4
2.1.3. Gestión Inadecuada de Contraseñas	4
2.2. Soluciones Propuestas	4
2.2.1. Inyección SQL	4
2.2.2. Exposición de Datos Sensibles	5
2.2.3. Gestión Inadecuada de Contraseñas	5
2.3. Ejemplos de Aplicación en un Proyecto Real	5
2.3.1. Inyección SQL	5
2.3.2. Exposición de Datos Sensibles	5
2.3.3. Gestión Inadecuada de Contraseñas	5

1. Caso de vulnerabilidad en Equifax

1.1. ¿Qué ocurrió?

En septiembre de 2017, Equifax, una de las principales agencias de informes crediticios de EE. UU., anunció que había sufrido una violación de seguridad que expuso la información personal de aproximadamente 143 millones de personas. Los atacantes explotaron una vulnerabilidad en Apache Struts, un marco de trabajo de código abierto utilizado por Equifax para sus aplicaciones web. [1] Aunque el parche para esta vulnerabilidad (CVE-2017-5638) fue lanzado en marzo de 2017, Equifax no lo aplicó a tiempo, lo que permitió a los atacantes acceder a datos sensibles como nombres, números de seguro social, fechas de nacimiento y, en algunos casos, números de licencia de conducir. [2]

1.2. ¿Qué tipo de vulnerabilidad fue?

La vulnerabilidad explotada fue una ejecución remota de código (RCE) en Apache Struts, específicamente CVE-2017-5638. Esta falla permitía a los atacantes ejecutar comandos maliciosos en el servidor al enviar solicitudes HTTP manipuladas, aprovechando el procesamiento de encabezados de tipo de contenido por parte de Struts. [3]

1.3. ¿Cuál fue el riesgo y el impacto?

Riesgo: Los atacantes obtuvieron acceso no autorizado a sistemas internos de Equifax, lo que les permitió extraer grandes cantidades de datos personales. [4]

Impacto:

- Exposición de información personal de aproximadamente 143 millones de personas.
- Pérdida de confianza por parte de los consumidores y daño significativo a la reputación de la empresa.
- Multas y sanciones legales, incluyendo un acuerdo de \$575 millones con la Comisión Federal de Comercio (FTC).

1.4. ¿Qué soluciones se implementaron?

- Aplicación de parches: Equifax finalmente aplicó el parche de seguridad para la vulnerabilidad en Apache Struts. [4]
- Mejoras en la seguridad:
 - Implementación de certificados SSL actualizados para mejorar la detección de tráfico sospechoso.
 - Revisión y fortalecimiento de las políticas de seguridad internas.
 - Colaboración con firmas de ciberseguridad para investigar y mitigar el incidente.
- Compensación a los afectados:
 - Ofrecimiento de servicios gratuitos de monitoreo de crédito e identidad.
 - Establecimiento de un fondo de compensación como parte del acuerdo con la FTC.

2. Riesgos de Seguridad en el Desarrollo de Software

2.1. Riesgos de Seguridad Identificados

2.1.1. Inyección SQL

- **Descripción:** Un atacante inserta código malicioso en una consulta SQL, accediendo o manipulando bases de datos no autorizadamente.

2.1.2. Exposición de Datos Sensibles

- **Descripción:** Datos privados como contraseñas o información bancaria quedan accesibles debido a una mala gestión de seguridad.

2.1.3. Gestión Inadecuada de Contraseñas

- **Descripción:** Almacenar contraseñas en texto plano o usar algoritmos de cifrado débiles facilita su robo.

2.2. Soluciones Propuestas

2.2.1. Inyección SQL

- Uso de sentencias preparadas (prepared statements) y consultas parametrizadas.
- Validar y sanitizar entradas del usuario.

2.2.2. Exposición de Datos Sensibles

- Cifrar toda la información sensible (en tránsito y en reposo).
- Minimizar la exposición de datos en APIs o respuestas.

2.2.3. Gestión Inadecuada de Contraseñas

- Almacenar contraseñas usando algoritmos de hash robustos (bcrypt, Argon2).
- Aplicar políticas de contraseñas fuertes y autenticación multifactor.

2.3. Ejemplos de Aplicación en un Proyecto Real

2.3.1. Inyección SQL

- En una aplicación web de ventas, usar `PreparedStatement` en Java en vez de concatenar strings en consultas SQL.

2.3.2. Exposición de Datos Sensibles

- En un sistema de pagos, cifrar datos de tarjetas de crédito usando `AES-256` antes de almacenarlos en la base de datos.

2.3.3. Gestión Inadecuada de Contraseñas

- En una app de registro de usuarios, aplicar `bcrypt` para almacenar contraseñas y obligar a cambiar la clave cada 90 días.

Bibliografía

- [1] BleepingComputer. (2017, September 14). Equifax Confirms Hackers Used Apache Struts Vulnerability to Breach Its Servers. BleepingComputer. <https://www.bleepingcomputer.com/news/security/equifax-confirms-hackers-used-apache-struts-vulnerability-to-breach-its-server/>
- [2] SecurityWeek. (2017, September 14). Equifax Confirms Apache Struts Flaw Used in Hack. SecurityWeek. <https://www.securityweek.com/equifax-confirms-apache-struts-flaw-used-hack/>
- [3] The Hacker News. (2017, September 14). Equifax Hackers Exploited Apache Struts Flaw, Company Admits. The Hacker News. <https://thehackernews.com/2017/09/equifax-apache-struts.html>
- [4] Time. (2019, July 22). Equifax to Pay at Least \$575 Million in Settlement Over Massive 2017 Data Breach. Time. <https://time.com/5640512/equifax-settlement-ftc-125/>